

Day 35 - Project: Ransomware Attack Reconstruction & Executive Reporting

Prepared By

Shibindas PM

SOC Analyst Intern

1. Introduction

A ransomware attack is one of the most damaging types of cyberattacks faced by modern organizations. In such attacks, malicious software encrypts critical files and systems, making them inaccessible until a ransom is paid. These incidents often begin with common attack vectors such as phishing emails, malicious attachments, or compromised credentials. Once attackers gain access, they attempt to escalate privileges, steal credentials, move laterally across the network, and finally encrypt valuable organizational data.

The objective of this project is to reconstruct the ransomware attack based on the provided incident timeline, identify each stage of the attack, analyze the root cause, evaluate the effectiveness of existing security controls, and recommend improvements for future prevention and detection. The investigation follows the methodology commonly used by Security Operations Centers (SOC) and Incident Response (IR) teams.

2. Scenario Overview

A manufacturing company experienced a ransomware attack that significantly disrupted its production operations. The attack began when an employee received a phishing email containing a malicious attachment. After opening the attachment, malicious code executed through PowerShell, allowing the attacker to gain an initial foothold within the organization's network.

The attacker then performed credential dumping to obtain administrator credentials and used those credentials to move laterally across multiple systems. After compromising several endpoints, the ransomware payload was deployed, encrypting files across the organization's infrastructure. Eventually, ransom notes appeared on approximately 75 endpoints, and production systems became unavailable, causing major operational disruption.

This incident demonstrates a typical multi-stage ransomware attack where the attacker progresses through initial access, execution, credential theft, lateral movement, and impact before the organization can effectively respond.

3. Attack Timeline Reconstruction

Attack Timeline

Time	Attack Stage	Description
08:15 AM	Initial Access	An employee received a phishing e mail containing a malicious attachment disguised as a legitimate business document.
08:17 AM	User Execution	The employee opened the malicious attachment, allowing the embedded malware to execute on the workstation.
08:18 AM	Execution	PowerShell was launched by the malware to download and execute additional malicious payloads while attempting to evade traditional antivirus detection.
08:25 AM	Credential Access	The attacker performed credential dumping to extract user and administrator credentials from the compromised system.
08:40 AM	Lateral Movement	Using the stolen credentials, the attacker accessed multiple computers and servers within the internal network, spreading the malware to additional systems.
09:05 AM	Impact Preparation	The ransomware payload began encrypting files on compromised endpoints and shared network resources.
09:15 AM	Ransomware Execution	Ransom notes appeared on approximately 75 endpoints, informing users that their files had

been encrypted and demanding payment.

09:20 AM	Business Impact	Critical production systems became unavailable, disrupting manufacturing operations and causing significant business downtime.
----------	-----------------	--

4. Detailed Timeline Analysis

Initial Access (08:15 AM)

The attack began with a phishing email sent to an employee. The email likely impersonated a trusted organization and contained a malicious attachment. Because the email was convincing, the employee opened the attachment, unknowingly initiating the attack.

Objective of the attacker:

- Deliver malware to the victim's computer.
- Gain an initial foothold in the organization.

User Execution (08:17 AM)

After opening the attachment, malicious code executed on the employee's workstation. This execution allowed the malware to begin communicating with the attacker's infrastructure and prepare for additional malicious activities.

Objective of the attacker:

- Execute malware on the victim's device.
- Establish persistence for continued access.

PowerShell Execution (08:18 AM)

The malware launched PowerShell to execute commands and download additional payloads. PowerShell is frequently abused by attackers because it is a trusted Windows administration tool and can help bypass traditional antivirus detection.

Objective of the attacker:

- Download ransomware components.
- Execute malicious scripts.
- Evade detection.

Credential Dumping (08:25 AM)

The attacker extracted credentials stored in the operating system. These credentials enabled access to higher-privileged accounts and additional systems within the network.

Objective of the attacker:

- Obtain administrator credentials.
- Prepare for lateral movement.

Lateral Movement (08:40 AM)

Using the stolen credentials, the attacker accessed multiple systems across the organization's network. This allowed the ransomware to spread beyond the initially compromised workstation.

Objective of the attacker:

- Increase the number of compromised systems.
- Reach high-value servers.

File Encryption (09:05 AM)

After compromising multiple systems, the ransomware encrypted files stored on local machines and shared network drives. Users could no longer access their data.

Objective of the attacker:

- Maximize operational disruption.
- Force the organization to consider paying the ransom.

Ransom Note (09:15 AM)

A ransom message appeared on approximately 75 endpoints, informing users that their files had been encrypted and providing instructions for ransom payment.

Objective of the attacker:

- Demand payment.
- Pressure the organization to comply.

Production Systems Impact (09:20 AM)

The ransomware affected critical production systems, interrupting manufacturing operations. Employees were unable to access essential systems, leading to significant operational downtime.

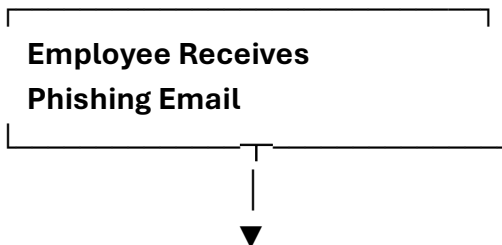
Business Impact:

- Production halted.
- Employees unable to perform normal operations.
- Financial losses due to downtime.
- Potential reputational damage.

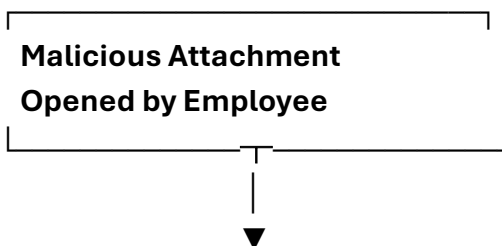
5. Attack Timeline Diagram

RANSOMWARE ATTACK TIMELINE

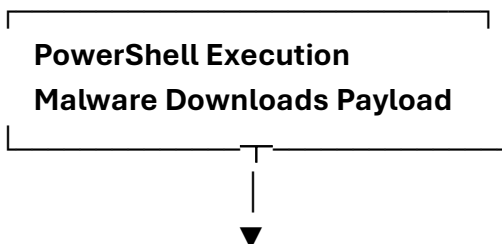
08:15 AM



08:17 AM

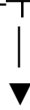


08:18 AM



08:25 AM

**Credential Dumping
Administrator Credentials**



08:40 AM

**Lateral Movement
Multiple Systems Accessed**



09:05 AM

**File Encryption Begins
Ransomware Payload Active**



09:15 AM

**Ransom Note Displayed
75 Endpoints Affected**



09:20 AM

**Production Systems
Become Unavailable**

6.MITRE ATT&CK Mapping

The **MITRE ATT&CK Framework** is a globally recognized knowledge base that categorizes adversary behavior into tactics and techniques based on real-world cyberattacks. It helps security professionals understand how attackers operate and enables organizations to improve detection, prevention, and incident response capabilities.

MITRE ATT&CK Mapping Table

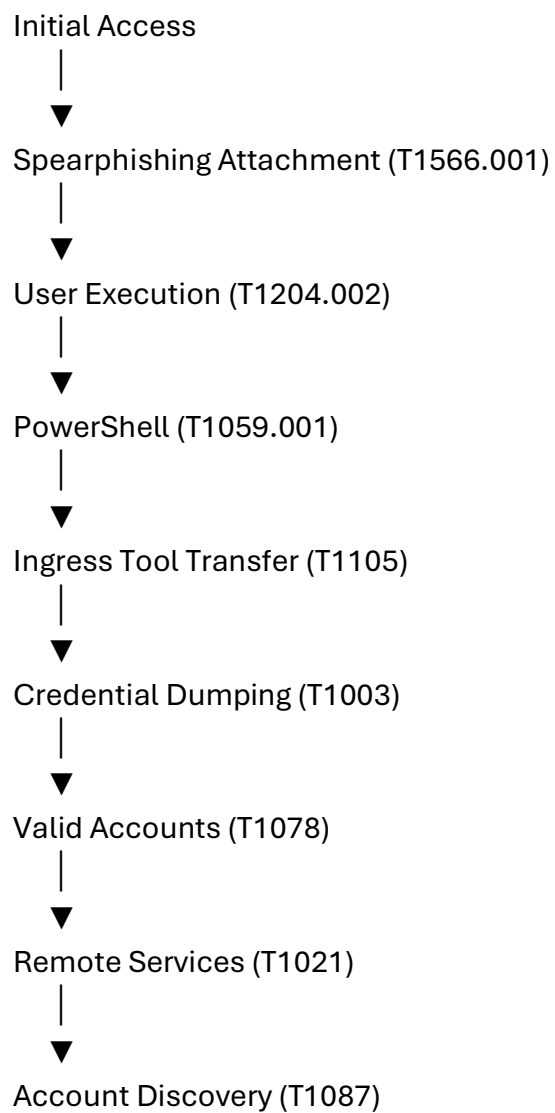
Attack Stage

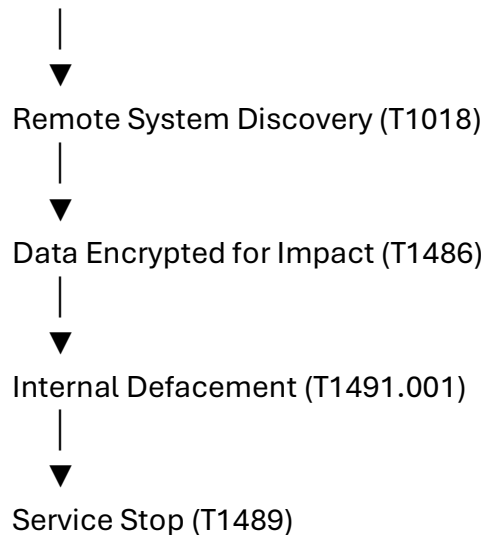
Attack Stage	Activity	ATT&CK Tactic	Technique ID	Technique Name	Explanation
1	Phishing Email	Initial Access	T1566.001	Spearphishing Attachment	The attacker delivered a malicious attachment through a phishing email to gain initial access. The victim
2	User Opens Attachment	Execution	T1204.002	User Execution: Malicious File	executed the malicious file by opening the email attachment. Malware used PowerShell to
3	PowerShell Execution	Execution	T1059.001	PowerShell	execute commands and download additional payloads. Additional malicious
4	Malware Downloads Payload	Command and Control	T1105	Ingress Tool Transfer	files were downloaded from the attacker's infrastructure. Credentials
5	Credential Dumping	Credential Access	T1003	OS Credential Dumping	stored in memory were extracted to obtain

6	Administrator Credential Use	Privilege Escalation	T1078	Valid Accounts	privileged access. The attacker used stolen administrator credentials to gain elevated privileges. Stolen credentials enabled the attacker to move laterally across the internal network.
7	Multiple Systems Accessed	Lateral Movement	T1021	Remote Services	The attacker identified available accounts and privileged users. Additional computers and servers were discovered before spreading the ransomware.
8	Internal Discovery	Discovery	T1087	Account Discovery	The ransomware encrypted files on compromised systems to deny access.
9	Network Enumeration	Discovery	T1018	Remote System Discovery	The ransomware displayed
10	File Encryption	Impact	T1486	Data Encrypted for Impact	
11	Ransom Note Displayed	Impact	T1491.001	Internal Defacement	

					ransom instructions on affected endpoints. Critical business services became unavailable, disrupting production operations.
12	Production Systems Down	Impact	T1489	Service Stop	

Attack Flow Using MITRE ATT&CK





Explanation of Each ATT&CK Technique

1. Spearphishing Attachment (T1566.001)

The attacker initiated the attack by sending a phishing email with a malicious attachment. When the employee trusted and opened the attachment, the attack began.

Purpose: Gain initial access.

2. User Execution (T1204.002)

The malicious file required user interaction. Once opened, the embedded malware executed on the victim's workstation.

Purpose: Execute malicious code.

3. PowerShell (T1059.001)

PowerShell was used to execute malicious commands and retrieve additional payloads while blending in with legitimate administrative activity.

Purpose: Execute scripts and evade detection.

4. Ingress Tool Transfer (T1105)

The attacker downloaded additional ransomware components from an external server after gaining initial access.

Purpose: Deliver tools needed for later attack stages.

5. OS Credential Dumping (T1003)

The malware extracted passwords and authentication data from the compromised system to obtain higher-level access.

Purpose: Steal user and administrator credentials.

6. Valid Accounts (T1078)

Instead of exploiting another vulnerability, the attacker reused stolen credentials to access privileged systems.

Purpose: Escalate privileges using legitimate accounts.

7. Remote Services (T1021)

The attacker moved laterally through the organization's network using valid credentials and remote administration protocols.

Purpose: Spread the attack to additional systems.

8. Account Discovery (T1087)

User and administrator accounts were identified to locate high-value targets.

Purpose: Gather information about privileged accounts.

9. Remote System Discovery (T1018)

The attacker scanned the internal network to identify servers, workstations, and other devices for further compromise.

Purpose: Identify additional targets.

10. Data Encrypted for Impact (T1486)

The ransomware encrypted files across compromised systems, making business data inaccessible.

Purpose: Disrupt operations and demand ransom.

11. Internal Defacement (T1491.001)

A ransom note was displayed on infected systems with payment instructions.

Purpose: Notify victims and pressure them to pay.

12. Service Stop (T1489)

Critical production services became unavailable because systems were encrypted and no longer operational.

Purpose: Maximize operational disruption.

7.Root Cause Analysis

Root Cause Analysis (RCA) is a systematic process used to identify the underlying causes of a cybersecurity incident rather than focusing only on its visible effects.

Understanding the root causes helps organizations improve their security posture, prevent similar attacks, and strengthen incident response capabilities.

In this ransomware incident, the investigation revealed that multiple security weaknesses contributed to the successful compromise of the organization's network. The attack progressed through several stages, beginning with phishing and ending with widespread ransomware encryption of production systems.

1: How did the attackers enter the environment?

The attackers gained initial access through a **phishing email** containing a malicious attachment. The email was crafted to appear legitimate, encouraging the employee to trust the sender and open the attachment.

When the employee opened the attachment, malicious code executed on the workstation. This execution launched **PowerShell**, which downloaded additional ransomware components from the attacker's infrastructure.

The compromised workstation became the attacker's initial foothold inside the corporate network. From there, the attackers expanded their access by stealing credentials and moving laterally to other systems.

Root Cause

- Phishing email successfully bypassed email security.
- Employee opened the malicious attachment.
- Malware executed without being blocked.
- Initial endpoint became compromised.

2: What security controls failed?

Several security controls either failed or were insufficient to stop the attack.

1. Email Security Gateway

The phishing email reached the employee's inbox, indicating that the organization's email filtering system failed to detect or quarantine the malicious message.

Impact:

- Initial infection was not prevented.

3. Endpoint Protection

The endpoint security solution did not prevent the execution of the malicious attachment or the PowerShell process.

Impact:

- Malware executed successfully.

4. PowerShell Restrictions

PowerShell was allowed to execute malicious commands without restriction or alerting.

Impact:

- Malware downloaded additional payloads.

5. Privileged Access Management

The attackers successfully obtained administrator credentials through credential dumping.

Impact:

- Privilege escalation became possible.

6. Network Segmentation

The attacker moved laterally across multiple systems without encountering sufficient segmentation or access restrictions.

Impact:

- Ransomware spread rapidly.

7. Backup Strategy

Although not explicitly mentioned in the scenario, the widespread impact suggests backups were either unavailable, inaccessible, or not adequately protected.

Impact:

- Business recovery became more difficult.

Summary of Failed Controls

Security Control	Failure
Email Gateway	Phishing email delivered successfully
User Awareness	Employee opened malicious attachment
Endpoint Protection	Malware execution not blocked
PowerShell Controls	Malicious scripts executed
Privileged Access Management	Credentials stolen
Network Segmentation	Lateral movement succeeded
Backup Protection	Recovery significantly impacted

Several security technologies should have generated alerts during different stages of the attack.

Email Security Gateway

Should have detected:

- Suspicious sender
- Malicious attachment
- Phishing indicators

Security Information and Event Management (SIEM)

Should have correlated:

- Phishing event
- PowerShell execution
- Authentication anomalies
- Lateral movement
- File encryption

Identity Monitoring

Should have detected:

- Credential dumping
- Abnormal administrator logins
- Multiple failed authentication attempts

Network Monitoring

Should have detected:

- Unusual SMB traffic
- Remote administrative access
- Lateral movement
- Command-and-control communications

File Integrity Monitoring

Should have detected:

- Rapid file modifications
- Mass encryption activity

- Unauthorized file changes

Expected Detection Timeline

Attack Stage	Security Tool
Phishing Email	Email Gateway
Malicious Attachment	Antivirus / EDR
PowerShell Execution	EDR / SIEM
Credential Dumping	EDR
Lateral Movement	SIEM / IDS / Network Monitoring
File Encryption	File Integrity Monitoring / EDR
Production Impact	SOC Monitoring Dashboard

Question 4: Why did the ransomware succeed?

The ransomware attack succeeded because multiple defensive layers failed, allowing the attacker to progress through each stage of the attack without effective detection or containment.

1. Successful Phishing Attack

The phishing email deceived the employee into opening a malicious attachment.

2. Lack of Early Detection

PowerShell execution and malware activity were not detected quickly enough.

3. Credential Theft

The attacker successfully obtained administrator credentials, enabling access to additional systems.

4. Unrestricted Lateral Movement

The network lacked sufficient segmentation, allowing the attacker to spread the ransomware across multiple endpoints.

5. Delayed Incident Response

The attack was not contained before ransomware execution began.

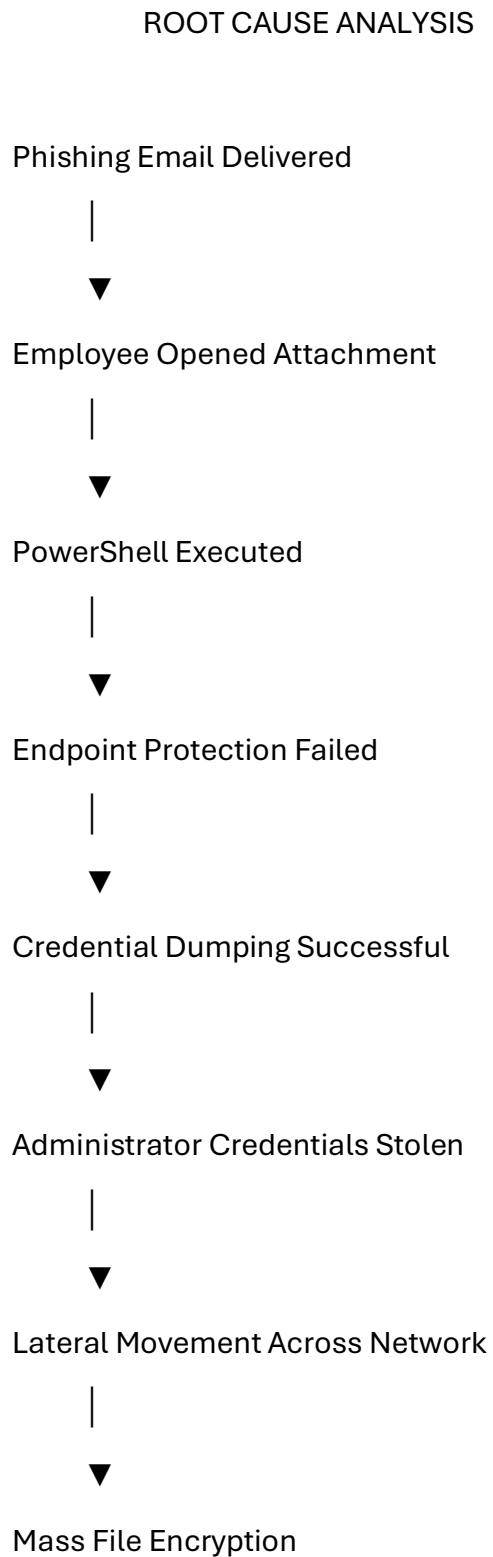
6. Inadequate Endpoint Protection

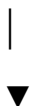
The endpoint security solution failed to stop malicious processes and ransomware behaviour.

7. Insufficient Backup Protection

The scenario indicates that production systems were significantly affected, suggesting that recovery mechanisms were not immediately effective.

Root Cause Summary Diagram





Production Systems Down

Key Findings

Area	Finding
Initial Access	Phishing email with malicious attachment
Primary Weakness	Human error and phishing susceptibility
Technical Weakness	PowerShell misuse and insufficient endpoint protection
Identity Weakness	Credential dumping led to privileged access
Network Weakness	Poor segmentation enabled lateral movement
Detection Weakness	Security tools failed to identify attacker activity early
Business Impact	Production systems disrupted by ransomware

SOC Detection Gap Analysis

A **Detection Gap Analysis** is a critical activity performed by Security Operations Centers (SOC) after a cybersecurity incident. It helps identify weaknesses in monitoring capabilities, determine why malicious activities were not detected in time, and recommend improvements to strengthen future detection and response.

In this ransomware incident, the attacker successfully progressed through multiple attack stages without being stopped. This indicates that several security controls either failed to generate alerts or generated alerts that were not acted upon. The following analysis identifies these gaps and provides recommendations to improve the organization's detection capabilities.

1. Existing Detections That Should Have Triggered

Several security tools should have generated alerts during different phases of the ransomware attack.

Attack Stage	Expected Detection	Security Tool
--------------	--------------------	---------------

Phishing Email	Malicious attachment detection	Email Security Gateway
Attachment Opened	Suspicious file execution	Antivirus / EDR
PowerShell Execution	Suspicious PowerShell commands	EDR / SIEM
Credential Dumping	LSASS memory access	EDR
Lateral Movement	Remote login anomalies	SIEM / IDS
File Encryption	Mass file modification	File Integrity Monitoring (FIM)
Ransom Note	Ransomware behavior detection	EDR

2. Missing Detections

The investigation indicates that several important detections were either missing or insufficient.

a) PowerShell Monitoring

The organization did not effectively monitor PowerShell activity.

Missing Detection

- Encoded PowerShell commands
- PowerShell downloading remote files
- Suspicious script execution

Recommendation

- Enable PowerShell Script Block Logging.
- Monitor Event IDs 4103 and 4104.

b) Credential Dumping Detection

The attacker successfully dumped credentials without being detected.

Missing Detection

- Access to LSASS process
- Memory dumping
- Mimikatz-like behavior

Recommendation

- Enable Microsoft Defender Credential Guard.
- Configure EDR rules for credential dumping.

c) Lateral Movement Detection

Attackers moved across multiple systems without triggering alerts.

Missing Detection

- Remote Desktop (RDP) logins
- SMB administrative shares
- PsExec execution
- Windows Remote Management (WinRM)

Recommendation

- Monitor unusual authentication events.
- Detect abnormal remote administration activity.

d) File Encryption Detection

Mass encryption activity was not identified before production systems were impacted.

Missing Detection

- Large numbers of file rename operations
- Rapid file modifications
- Multiple file extensions changing simultaneously

Recommendation

- Deploy File Integrity Monitoring (FIM).
- Configure ransomware behavior detection policies.

3. Monitoring Improvements

The organization should strengthen its monitoring capabilities by implementing the following improvements.

Email Security

- Enable advanced phishing detection.
- Block macro-enabled attachments.
- Perform attachment sandboxing.
- Use URL reputation filtering.

Endpoint Monitoring

- Deploy Endpoint Detection and Response (EDR).
- Enable behavioral ransomware detection.
- Monitor suspicious child processes.
- Restrict unauthorized PowerShell execution.

Identity Monitoring

- Monitor privileged account usage.
- Detect impossible travel logins.
- Alert on privilege escalation events.
- Enable Multi-Factor Authentication (MFA).

Network Monitoring

- Deploy Intrusion Detection/Prevention Systems (IDS/IPS).
- Monitor SMB traffic.
- Detect unusual remote connections.
- Alert on lateral movement techniques.

SIEM Improvements

The SIEM should correlate events across multiple security tools to identify complex attack chains.

Example correlation rule:

Phishing Email

↓

PowerShell Execution

↓

Credential Dumping

↓

Administrator Login

↓

Multiple Remote Connections

↓

Mass File Encryption

4. Additional Log Sources Required

To improve visibility, the SOC should collect and analyze logs from multiple sources.

Log Source	Purpose
Windows Security Logs	User logins, privilege changes, process creation
PowerShell Logs	Script execution and command history
Sysmon Logs	Detailed process, network, and file activity
Active Directory Logs	Authentication and account management
DNS Logs	Malicious domain lookups
Firewall Logs	Network traffic analysis
Proxy Logs	Internet access monitoring
VPN Logs	Remote access monitoring
File Server Logs	File access and modifications
EDR Telemetry	Endpoint behavior and threat detection

Detection Gap Summary Table

Security Area	Current Gap	Recommended Improvement
Email Security	Phishing email delivered	Advanced email filtering and sandboxing
Endpoint Security	Malware execution not blocked	Deploy EDR with behavioral detection
PowerShell	No visibility	Enable Script Block Logging and monitoring
Credential Protection	Credential dumping undetected	Credential Guard and EDR detection rules
Network Monitoring	Lateral movement not detected	IDS/IPS and network segmentation
File Monitoring	Encryption detected too late	File Integrity Monitoring (FIM)
Identity Security	Privileged account misuse	MFA and privileged access monitoring
SIEM	Lack of event correlation	Implement correlation rules and use cases

SOC Detection Workflow

Phishing Email

|



Email Gateway Alert



PowerShell Execution



EDR Alert



Credential Dumping



SIEM Correlation



Lateral Movement



Network Alert



Mass File Encryption



SOC Analyst Investigation



Incident Containment

Business Impact Assessment

A Business Impact Assessment (BIA) evaluates how a cybersecurity incident affects an organization's operations, finances, reputation, and legal compliance. In this ransomware incident, the encryption of critical systems caused significant disruption to manufacturing operations and business continuity.

1. Operational Impact

The ransomware attack severely disrupted the organization's daily operations. Production systems became unavailable after multiple endpoints were encrypted, preventing employees from accessing business-critical applications and files.

Operational Consequences

- Manufacturing production stopped.
- Employees could not access business systems.
- Internal communication was disrupted.
- File servers became unavailable.
- IT staff focused entirely on incident response.
- Business processes experienced significant downtime.

Impact Level: Critical

2. Financial Impact

The ransomware incident resulted in both direct and indirect financial losses.

Direct Costs

- Incident response and forensic investigation.
- System restoration and recovery.
- Replacement of damaged systems.
- Overtime for IT and security teams.

Indirect Costs

- Production downtime.
- Delayed customer deliveries.
- Lost business opportunities.
- Reduced employee productivity.

Estimated Business Impact: High Financial Loss

3. Reputation Damage

The incident negatively affected customer confidence and the organization's reputation.

Possible Consequences

- Loss of customer trust.
- Reduced confidence from suppliers.
- Negative media coverage.
- Increased concern among investors.
- Damage to the company's brand image.

Impact Level: High

4. Regulatory and Compliance Concerns

Depending on the type of information stored in the affected systems, the organization may be required to notify regulators, customers, or business partners.

Potential Concerns

- Data breach notification requirements.
- Compliance audits.
- Customer privacy concerns.
- Legal investigations.
- Industry-specific regulatory obligations.

Impact Level: Medium to High

Risk Category	Likelihood	Impact	Risk Rating
Operational Disruption	High	Critical	Critical
Financial Loss	High	High	Critical
Reputation Damage	Medium	High	High
Regulatory Issues	Medium	Medium	Medium
Future Ransomware Attacks	High	High	Critical

Overall Risk Rating

Critical

Justification

The ransomware attack affected approximately **75 endpoints** and disrupted production systems, causing major operational and financial consequences. Because core business operations were interrupted and multiple systems required recovery, the overall organizational risk is assessed as **Critical**.

Executive Report

Ransomware Incident Executive Report

Prepared For:

- Chief Executive Officer (CEO)
- Chief Information Officer (CIO)
- Board of Directors

1. Incident Overview

On the morning of the incident, a phishing email containing a malicious attachment was delivered to an employee. After the attachment was opened, malicious software executed and established access to the organization's internal network.

The attacker used PowerShell to execute additional malicious code, stole user credentials, and moved laterally across multiple systems. The ransomware then encrypted files on approximately 75 endpoints, affecting production systems and interrupting manufacturing operations.

2. Business Impact

The ransomware attack caused significant disruption to business operations.

Key Impacts

- Production systems became unavailable.
- Manufacturing activities were interrupted.
- Employees lost access to critical files.
- Incident response and recovery required significant IT resources.
- Customer services experienced delays.

Overall business operations were affected for several hours while the incident response team worked to contain and recover from the attack.

3. Recovery Status

The Incident Response Team immediately initiated containment procedures.

Actions Taken

- Isolated infected systems.
- Disabled compromised user accounts.
- Blocked malicious network activity.
- Began forensic investigation.

- Restored systems from backups.
- Reset administrator credentials.
- Conducted malware removal.

Production services were gradually restored after validation and recovery activities.

4. Recommendations

To reduce the likelihood of similar incidents, the following actions are recommended:

1. Strengthen email security controls.
2. Conduct regular phishing awareness training.
3. Deploy Endpoint Detection and Response (EDR).
4. Implement Multi-Factor Authentication (MFA).
5. Restrict PowerShell usage where appropriate.
6. Improve SIEM monitoring and alert correlation.
7. Implement network segmentation.
8. Maintain secure offline backups.
9. Perform regular vulnerability assessments.
10. Conduct periodic incident response exercises.

